Definitions - C

PURPOSE: This document provides a list of words and definitions to clarify Information Specific (IT) terminology contained within the State of Wyoming Policies and Standards.

I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as “agencies”). This policy is also applicable to consultants, affiliates, and temporary employees.

II. DEFINITIONS

- Card Verification Value (CVV/CVV2): Both of these terms are commonly used to refer to the number printed on a card to help secure "card not present" transactions - other terms include CVC, CID, and CSC. To be precise, the code printed on the card is actually the CVV2 - and the CVV is integrity-check data encoded on the magnetic strip - but both terms are widely used online. (SOURCE: VERIZON PCI SECURITY)

- Cardholder: An individual possessing an issued Personal Identity Verification (PIV) card. (SOURCE: FIPS 201)

- Cardholder Data Environment (CDE): All people, processes, and technologies that store, process, or transmit cardholder data (CHD) or sensitive authentication data (SAD). (SOURCE: VERIZON PCI SECURITY)

- Center for Internet Security (CIS) Benchmarks: CIS benchmarks are configuration baselines and best practices for securely configuring a system.

- Certificate: A digital representation of information which at least 1. identifies the certification authority issuing it, 2. names or identifies its subscriber, 3. contains the subscriber's public key, 4. identifies its operational period, and 5. is digitally signed by the certification authority issuing it. (SOURCE: NIST SP 800-32); A set of data that uniquely identifies an affiliate, contains the affiliate's public key and possibly other information, and is digitally signed by a trusted party, thereby binding the public key to the affiliate. Additional information in the certificate could specify how the key is used and its crypto period. (SOURCE: NIST SP 800-21); A set of data that uniquely identifies a key pair and an owner that is authorized to use the key pair. The certificate contains the owner's public key and possibly other information, and is digitally signed by a Certification Authority (i.e., a trusted party), thereby binding the public key to the owner. (SOURCE: FIPS 186)

- Certificate Management: Process whereby certificates (as defined above) are generated, stored, protected, transferred, loaded, used, and destroyed. (SOURCE: CNSSI-4009)

- Certification: A comprehensive assessment of the management, operational, and technical security controls in an information system, made in support of security accreditation, to determine the extent to which the controls are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting the security requirements for the system. (SOURCE: FIPS 200); The process of verifying the correctness of a statement or claim and issuing a certificate as to its correctness. (SOURCE: FIPS 201); Comprehensive evaluation of the technical and nontechnical security safeguards of an information system to support the accreditation process that establishes the extent to which a particular design and implementation meets a set of specified security requirements. See Security Control Assessment. (SOURCE: CNSSI-4009)

- Chain of Custody: A process that tracks the movement of evidence through its collection, safeguarding, and analysis lifecycle by documenting each person who handled the evidence, the date/time it was collected or transferred, and the purpose for the transfer. (SOURCE: NIST SP 800-72; CNSSI-4009)

- Chain of Evidence: A process and record that shows who obtained the evidence, where and when the evidence was obtained, who secured the evidence, and who had control or possession of the evidence. The "sequencing" of the chain of evidence follows this order: collection and identification; analysis; storage; preservation; presentation in court; return to owner. (SOURCE: CNSSI-4009)

- Change: The addition, modification, or removal of anything that could have an effect on IT services. The scope should include changes to all architectures, processes, tools, metrics, and documentation, as well as changes to IT services and other configuration items. (SOURCE: ITIL V3)

- Change Control: A formal process used to ensure that a process, product, service, or technology component is modified only in accordance with agreed-upon rules. Many organizations have formal Change Control Boards that review and approve proposed modifications to technology infrastructures, systems, and applications. Data Governance programs often strive to extend the scope of change control to include additions, modifications, or deletions to data models and values for reference/master data. (SOURCE: Data Governance Institute)

- Change Advisory Board (CAB): A committee that makes decisions regarding whether or not proposed changes to a software project should be implemented. In short, any changes to the Baseline Requirements agreed upon with the client, should be taken up by the project team upon on approval from this committee. If any change is agreed by the committee, it is communicated to the project team and client and the requirement is Baselined with the change. The change control board is constituted of project stakeholders or their representatives. The authority of the change advisory board may vary from project to project, but decisions reached by the change advisory board are often accepted as final and binding. The decision of acceptance of the changes also depends upon the stage or phase of the project. The main objective is to ensure acceptance of the project (deliverable) by the client. (SOURCE: WIKIPEDIA)

- CIO Service Desk: service desk support team, which can be reached via the service desk portal https://wyoprod.servicenowservices.com/ets, email at helpdesk@wyo.gov, or by phone at +1 (307) 777-5000

- Clear: To use software or hardware products to overwrite storage space on the media with non-sensitive data. This process may include overwriting not only the logical storage location of a file(s) (e.g., file allocation table) but also may include all addressable locations. See comments on Clear/Purge Convergence. (SOURCE: NIST SP 800-88)

- Clear Text: Information that is not encrypted. (SOURCE: NIST SP 800-82)

- Clearing: Removal of data from an information system, its storage devices, and other peripheral devices with storage capacity in such a way that the data may not be reconstructed using common system capabilities (i.e., through the keyboard); however, the data may be reconstructed using laboratory methods. (SOURCE: CNSSI-4009)

- Client: A system affiliate, usually a computer process acting on behalf of a human user that makes use of a service provided by a server. (SOURCE: NIST SP 800-32)

- Closed Security Environment: Environment providing sufficient assurance that applications and equipment are protected against the introduction of malicious logic during an information system life cycle. Closed security is based upon a system's developers, operators, and maintenance personnel having sufficient clearances, authorization, and configuration control. (SOURCE: CNSSI-4009)

- Cloud Computing: A model for enabling on-demand network access to a shared pool of configurable IT capabilities/resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction. It allows users to access technology-based services from the network cloud without knowledge of, expertise with, or control over the technology infrastructure that supports them. This cloud model is composed of five essential characteristics (on-demand self- service, ubiquitous network access, location-independent resource pooling, rapid elasticity, and measured service); three service delivery models (Cloud Software as a Service [SaaS], Cloud Platform as a Service [PaaS], and Cloud Infrastructure as a Service [IaaS]); and four models for enterprise access (Private cloud, Community cloud, Public cloud, and Hybrid cloud). Note: Both the user's data and essential security services may reside in and be managed within the network cloud. (SOURCE: CNSSI-4009)

- Collaborative Computing: the use of computer systems, software tools, and networks to enable multiple users to work together on projects and tasks simultaneously, this may include remote meeting devices and/or software, cameras, workflow, and knowledge management software.

- Cold Site: Backup site that can be up and operational in a relatively short time span, such as a day or two. Provision of services, such as telephone lines and power, is taken care of, and the basic office furniture might be in place, but there is unlikely to be any computer equipment, even though the building might well have a network infrastructure and a room ready to act as

a server room. In most cases, cold sites provide the physical location and basic services. (SOURCE: CNSSI-4009) A backup facility that has the necessary electrical and physical components of a computer facility but does not have the computer equipment in place. The site is ready to receive the necessary replacement computer equipment in the event that the user has to move from their main computing location to an alternate site. (SOURCE: NIST SP 800-34)

- Commingling: The presence of FTI and non-FTI data together on the same paper or electronic media. (SOURCE: IRS PUB 1075)

- Commercial Off The Shelf (COTS): Commercially available hardware and software

- Common Vulnerabilities and Exposures (CVE): A dictionary of common names for publicly known information system vulnerabilities. (SOURCE: NIST SP 800-51; CNSSI-4009) An SCAP specification that provides unique, common names for publicly known information system vulnerabilities. (SOURCE: NIST SP 800-128)

- Common Vulnerability Scoring System (CVSS): A SCAP specification for communicating the characteristics of vulnerabilities and measuring their relative severity. (SOURCE: NIST SP 800-128)

- Compensating Security Control: A management, operational, and/or technical control (i.e., safeguard or countermeasure) employed by an organization in lieu of a recommended security control in the low, moderate, or high baselines that provides equivalent or comparable protection for an information system. (SOURCE: CNSSI-4009)

- Compliance: A discipline, set of practices, and/or organizational group that deals with adhering to laws, regulations, standards, and contractual arrangements. Also, the adherence to requirements. Data Governance programs often support many types of compliance requirements: Regulatory compliance, contractual compliance, adherence to internal standards, policies, and architectures, and conformance to rules for data management, project management, and other disciplines. (SOURCE: Data Governance Institute)

- Comprehensive Testing: A test methodology that assumes explicit and substantial knowledge of the internal structure and implementation detail of

the assessment object. Also known as white box testing. (SOURCE: NIST SP 800-53A)

- Compromise: Disclosure of information to unauthorized persons or a violation of the security policy of a system in which unauthorized intentional or unintentional disclosure, modification, destruction, or loss of an object may have occurred. (SOURCE: NIST SP 800-32; CNSSI-4009)

- Component: A discrete, identifiable information technology asset (e.g., hardware, software, firmware) that represents a building block of an information system. Information system components include commercial information technology products. Also referred to as a system component. (SOURCE: NIST SP 800-53r4)

- Computer-Based Training: Computer-based training (CBT) is any course of instruction whose primary means of delivery is a computer. A CBT course (sometimes called courseware) may be delivered via a software product installed on a single computer, through a corporate or educational intranet, or over the Internet as Web-based training (SOURCE: TechTarget)

- Computer Cryptography: Use of a crypto-algorithm program by a computer to authenticate or encrypt/decrypt information. (SOURCE: CNSSI-4009)

- Computer Emergency Response Team (CERT): Acronym for Carnegie Mellon University's "Computer Emergency Response Team." The CERT Program develops and promotes the use of appropriate technology and systems management practices to resist attacks on networked systems, limit damage, and to ensure continuity of critical services. (SOURCE: PCI DSS Glossary)

- Computer Network Attack (CNA): Actions taken through the use of computer networks to disrupt, deny, degrade, or destroy information resident in computers and computer networks or the computers and networks themselves. (SOURCE: CNSSI-4009)

- Computer Network Defense (CND): Actions taken to defend against unauthorized activity within computer networks. CND includes monitoring, detection, analysis (such as trend and pattern analysis), and response and restoration activities. (SOURCE: CNSSI-4009)

- Computer Network Exploitation (CNE): Enabling operations and intelligence collection capabilities conducted through the use of computer networks to

gather data from target or adversary information systems or networks. (SOURCE: CNSSI-4009)

- Confidential or High Sensitivity. Confidential information is information whose loss, corruption, or unauthorized disclosure would seriously harm an individual's, business's, or the State's reputation or business position, resulting in severe financial and legal loss.

- Confidentiality: Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information. (SOURCE: NIST SP 800-53; NIST SP 80053A; NIST SP 800-18; NIST SP 800-27; NIST SP 800-60; NIST SP 800-37; FIPS 200; FIPS 199; 44 U.S.C., Sec. 3542) The property that sensitive information is not disclosed to unauthorized individuals, affiliates, or processes. (SOURCE: FIPS 140-2) The property that information is not disclosed to system affiliates (users, processes, devices) unless they have been authorized to access the information. (SOURCE: CNSSI-4009)

- Configuration Control: Process of controlling modifications to hardware, firmware, software, and documentation to protect the information system against improper modification prior to, during, and after system implementation. (SOURCE: CNSSI-4009; NIST SP 800-37; NIST SP 800-53)

- Configuration Item: Any component or other service asset that needs to be managed in order to deliver an IT service. (SOURCE: ITIL V3)

- Configuration Management: A structured process of managing and controlling changes to hardware, software, firmware, communications, and documentation throughout the system development life cycle. (SOURCE: IRS PUB 1075)

- Container: The file used by a virtual disk encryption technology to encompass and protect other files. (SOURCE: NIST SP 800-111)

- Contamination: Type of incident involving the introduction of data of one security classification or security category into data of a lower security classification or different security category. (SOURCE: CNSSI-4009)

- Continuing Professional Education (CPE): recurring specialized training

- Content Filtering: The process of monitoring communications such as email and Web pages, analyzing them for suspicious content, and preventing the

delivery of suspicious content to users. (SOURCE: NIST SP 800-114)

- Contingency Plan: Management policy and procedures used to guide an enterprise response to a perceived loss of mission capability. The Contingency Plan is the first plan used by enterprise risk managers to determine what happened, why, and what to do. It may point to the Continuity of Operations Plan (COOP) or Disaster Recovery Plan for major disruptions. (SOURCE: CNSSI-4009)

- Continuity of Operations (COOP) Plan: A predetermined set of instructions or procedures that describe how an organization's mission essential functions will be sustained within 12 hours and for up to 30 days as a result of a disaster event before returning to normal operations. (SOURCE: NIST SP 800-34) Management policy and procedures are used to guide an enterprise's response to a major loss of enterprise capability or damage to its facilities. The COOP is the third plan needed by the enterprise risk managers and is used when the enterprise must recover (often at an alternate site) for a specified period of time. Defines the activities of individual departments and agencies and their sub-components to ensure that their essential functions are performed. This includes plans and procedures that delineate essential functions, specify succession to office and the emergency delegation of authority, provide for the safekeeping of vital records and databases, identify alternate operating facilities, provide for interoperable communications, and validate the capability through tests, training, and exercises. (SOURCE: CNSSI-4009)

- Continuous Monitoring: The process implemented to maintain a current security status for one or more information systems or for the entire suite of information systems on which the operational mission of the enterprise depends. The process includes: 1. The development of a strategy to regularly evaluate selected IA controls/metrics; 2. Recording and evaluating IA-relevant events and the effectiveness of the enterprise in dealing with those events; 3. Recording changes to IA controls or changes that affect IA risks, and 4. Publishing the current security status to enable information-sharing decisions involving the enterprise. (SOURCE: CNSSI-4009) Maintaining ongoing awareness to support organizational risk decisions. (SOURCE: NIST SP 800- 137)

- Control: A means of managing risk or ensuring that an objective is achieved. Controls can be preventative, detective, or corrective and can be fully automated, procedural, or technology-assisted human-initiated activities. They can include actions, devices, procedures, techniques, or other measures. (SOURCE: Data Governance Institute)

- Controlled Access Area: Physical area (e.g., building, room, etc.) to which only authorized personnel are granted unrestricted access. All other personnel are either escorted by authorized personnel or are under continuous surveillance. (SOURCE: CNSSI-4009)

- Controlled Area: Any area or space for which the organization has confidence that the physical and procedural protections provided are sufficient to meet the requirements established for protecting the information and/or information system. (SOURCE: NIST SP 800-53)

- Cookie: A piece of state information supplied by a Web server to a browser in a response for a requested resource for the browser to store temporarily and return to the server on any subsequent visits or requests. (SOURCE: NIST SP 800-28) Data is exchanged between an HTTP server and a browser (a client of the server) to store state information on the client side and retrieve it later for server use. (SOURCE: CNSSI-4009)

- Corrective Action Plan (CAP): A report required to be filed semi-annually, detailing the agency's planned and completed actions to resolve findings identified during an IRS safeguard review. (SOURCE: IRS PUB 1075)

- Covert Testing: Testing performed using covert methods and without the knowledge of the organization's IT staff but with the full knowledge and permission of upper management. (SOURCE: NIST SP 800-115)

- Container: The file used by a virtual disk encryption technology to encompass and protect other files. (SOURCE: NIST SP 800-111)

- Critical Infrastructure: Systems and assets, whether physical or virtual, so vital to the U.S. that the incapacity or destruction of such systems and assets would have a debilitating impact on security, national economic security, national public health or safety, or any combination of those matters. [Critical Infrastructures Protection Act of 2001, 42 U.S.C. 5195c(e)] (SOURCE: CNSSI-4009)

- Criticality: A measure of the degree to which an organization depends on the information or information system for the success of a mission or of a business function. (SOURCE: NIST SP 800-60)

- Criminal Justice Information (CJI): Criminal Justice Information is the term used to refer to all of the FBI Criminal Justice Information Services provided

data necessary for law enforcement and civil agencies to perform their missions, including, but not limited to, biometric, identity history, biographic, property, and case/incident history data. The following categories of CJI describe the various data sets housed by the FBI CJIS architecture: - Biometric Data - data derived from one or more intrinsic physical or behavioral traits of humans, typically for the purpose of uniquely identifying individuals from within a population. It is used to identify individuals; it can include fingerprints, palm prints, iris scans, and facial recognition data. - Identity History Data - textual data that corresponds with an individual's biometric data, providing a history of criminal and/or civil events for the identified individual. - Biographic Data - information about individuals associated with a unique case and not necessarily connected to identity data. Biographic data does not provide a history of an individual, only information related to a unique case. - Property Data - information about vehicles and property associated with a crime when accompanied by any personally identifiable information (PII). - Case/Incident History - information about the history of criminal incidents. (SOURCE: FBI)

- Cryptographic Algorithm: A well-defined computational procedure that takes variable inputs, including a cryptographic key, and produces an output. (SOURCE: NIST SP 800-21; CNSSI-4009)

- Cyber Attack: A disabling attack via cyberspace, targeting an enterprise's use of cyberspace for the purpose of disrupting, destroying, or maliciously controlling a computing environment/infrastructure; or destroying the integrity of the data or stealing controlled information. (SOURCE: CNSSI-4009)

- Cyber Incident: Actions taken through the use of computer networks that result in an actual or potentially adverse effect on an information system and/or the information residing therein. See Incident. (SOURCE: CNSSI-4009)

- Cyber Infrastructure: Includes electronic information and communications systems and services and the information contained in these systems and services. Information and communications systems and services are composed of all hardware and software that process, store, and communicate information or any combination of all of these elements. Processing includes the creation, access, modification, and destruction of information. Storage includes paper, magnetic, electronic, and all other media types. Communications include the sharing and distribution of information. For example: computer systems; control systems (e.g., supervisory control and data acquisitionSCADA); networks, such as the

Internet; and cyber services (e.g., managed security services) are part of cyber infrastructure. (SOURCE: NISTIR 7628)

- Cybersecurity: The ability to protect or defend the use of cyberspace from cyberattacks. (SOURCE: CNSSI-4009)

- Cybersecurity Event: A change that may have an impact on organizational operations (including mission, capabilities, or reputation). (SOURCE: NIST CYBERSECURITY FRAMEWORK)

- Cyberspace: A global domain within the information environment consisting of the interdependent network of information systems infrastructures, including the Internet, telecommunications networks, computer systems, and embedded processors and controllers. (SOURCE: CNSSI-4009)

- Card Verification Value (CVV/CVV2): Both of these terms are commonly used to refer to the number printed on a card to help secure "card not present" transactions - other terms include CVC, CID, and CSC. To be precise, the code printed on the card is actually the CVV2 - and the CVV is integrity-check data encoded on the magnetic strip - but both terms are widely used online. (SOURCE: VERIZON PCI SECURITY)

- Cardholder: An individual possessing an issued Personal Identity Verification (PIV) card. (SOURCE: FIPS 201)

- Cardholder Data Environment (CDE): All people, processes, and technologies that store, process, or transmit cardholder data (CHD) or sensitive authentication data (SAD). (SOURCE: VERIZON PCI SECURITY)

- Center for Internet Security (CIS) Benchmarks: CIS benchmarks are configuration baselines and best practices for securely configuring a system.

- Certificate: A digital representation of information which at least 1. identifies the certification authority issuing it, 2. names or identifies its subscriber, 3. contains the subscriber's public key, 4. identifies its operational period, and 5. is digitally signed by the certification authority issuing it. (SOURCE: NIST SP 800-32); A set of data that uniquely identifies an affiliate, contains the affiliate’s public key and possibly other information, and is digitally signed by a trusted party, thereby binding the public key to the affiliate. Additional information in the certificate could specify how the key is used and its crypto period. (SOURCE: NIST SP 800-21); A set of data that uniquely identifies a key pair and an owner that is authorized to use the key pair. The

certificate contains the owner's public key and possibly other information, and is digitally signed by a Certification Authority (i.e., a trusted party), thereby binding the public key to the owner. (SOURCE: FIPS 186)

- Certificate Management: Process whereby certificates (as defined above) are generated, stored, protected, transferred, loaded, used, and destroyed. (SOURCE: CNSSI-4009)

- Certification: A comprehensive assessment of the management, operational, and technical security controls in an information system, made in support of security accreditation, to determine the extent to which the controls are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting the security requirements for the system. (SOURCE: FIPS 200); The process of verifying the correctness of a statement or claim and issuing a certificate as to its correctness. (SOURCE: FIPS 201); Comprehensive evaluation of the technical and nontechnical security safeguards of an information system to support the accreditation process that establishes the extent to which a particular design and implementation meets a set of specified security requirements. See Security Control Assessment. (SOURCE: CNSSI-4009)

- Chain of Custody: A process that tracks the movement of evidence through its collection, safeguarding, and analysis lifecycle by documenting each person who handled the evidence, the date/time it was collected or transferred, and the purpose for the transfer. (SOURCE: NIST SP 800-72; CNSSI-4009)

- Chain of Evidence: A process and record that shows who obtained the evidence, where and when the evidence was obtained, who secured the evidence, and who had control or possession of the evidence. The "sequencing" of the chain of evidence follows this order: collection and identification; analysis; storage; preservation; presentation in court; return to owner. (SOURCE: CNSSI-4009)

- Change: The addition, modification, or removal of anything that could have an effect on IT services. The scope should include changes to all architectures, processes, tools, metrics, and documentation, as well as changes to IT services and other configuration items. (SOURCE: ITIL V3)

- Change Control: A formal process used to ensure that a process, product, service, or technology component is modified only in accordance with agreed-upon rules. Many organizations have formal Change Control Boards that review and approve proposed modifications to technology

infrastructures, systems, and applications. Data Governance programs often strive to extend the scope of change control to include additions, modifications, or deletions to data models and values for reference/master data. (SOURCE: Data Governance Institute)

- Change Advisory Board (CAB): A committee that makes decisions regarding whether or not proposed changes to a software project should be implemented. In short, any changes to the Baseline Requirements agreed upon with the client should be taken up by the project team upon approval from this committee. If any change is agreed by the committee, it is communicated to the project team and client and the requirement is Baselined with the change. The change control board is constituted of project stakeholders or their representatives. The authority of the change advisory board may vary from project to project, but decisions reached by the change advisory board are often accepted as final and binding. The decision of acceptance of the changes also depends upon the stage or phase of the project. The main objective is to ensure acceptance of the project (deliverable) by the client. (SOURCE: WIKIPEDIA)

- Clear: To use software or hardware products to overwrite storage space on the media with non-sensitive data. This process may include overwriting not only the logical storage location of a file(s) (e.g., file allocation table) but also may include all addressable locations. See comments on Clear/Purge Convergence. (SOURCE: NIST SP 800-88)

- Clear Text: Information that is not encrypted. (SOURCE: NIST SP 800-82)

- Clearing: Removal of data from an information system, its storage devices, and other peripheral devices with storage capacity in such a way that the data may not be reconstructed using common system capabilities (i.e., through the keyboard); however, the data may be reconstructed using laboratory methods. (SOURCE: CNSSI-4009)

- Client: A system affiliate, usually a computer process acting on behalf of a human user that makes use of a service provided by a server. (SOURCE: NIST SP 800-32)

- Closed Security Environment: Environment providing sufficient assurance that applications and equipment are protected against the introduction of malicious logic during an information system's life cycle. Closed security is based upon a system's developers, operators, and maintenance personnel having sufficient clearances, authorization, and configuration control.

(SOURCE: CNSSI-4009)

- Cloud Computing: A model for enabling on-demand network access to a shared pool of configurable IT capabilities/resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction. It allows users to access technology-based services from the network cloud without knowledge of, expertise with, or control over the technology infrastructure that supports them. This cloud model is composed of five essential characteristics (on-demand self-service, ubiquitous network access, location-independent resource pooling, rapid elasticity, and measured service); three service delivery models (Cloud Software as a Service [SaaS], Cloud Platform as a Service [PaaS], and Cloud Infrastructure as a Service [IaaS]); and four models for enterprise access (Private cloud, Community cloud, Public cloud, and Hybrid cloud). Note: Both the user's data and essential security services may reside in and be managed within the network cloud. (SOURCE: CNSSI-4009)

- Collaborative Computing: the use of computer systems, software tools, and networks to enable multiple users to work together on projects and tasks simultaneously, this may include remote meeting devices and/or software, cameras, workflow, and knowledge management software.

- Cold Site: Backup site that can be up and operational in a relatively short time span, such as a day or two. Provision of services, such as telephone lines and power, is taken care of, and the basic office furniture might be in place, but there is unlikely to be any computer equipment, even though the building might well have a network infrastructure and a room ready to act as a server room. In most cases, cold sites provide the physical location and basic services. (SOURCE: CNSSI-4009) A backup facility that has the necessary electrical and physical components of a computer facility but does not have the computer equipment in place. The site is ready to receive the necessary replacement computer equipment in the event that the user has to move from their main computing location to an alternate site. (SOURCE: NIST SP 800-34)

- Commingling: The presence of FTI and non-FTI data together on the same paper or electronic media. (SOURCE: IRS PUB 1075)

- Commercial Off The Shelf (COTS): Commercially available hardware and software

- Common Vulnerabilities and Exposures (CVE): A dictionary of common

names for publicly known information system vulnerabilities. (SOURCE: NIST SP 800-51; CNSSI-4009) A SCAP specification that provides unique, common names for publicly known information system vulnerabilities. (SOURCE: NIST SP 800-128)

- Common Vulnerability Scoring System (CVSS): An SCAP specification for communicating the characteristics of vulnerabilities and measuring their relative severity. (SOURCE: NIST SP 800-128)

- Compensating Security Control: A management, operational, and/or technical control (i.e., safeguard or countermeasure) employed by an organization in lieu of a recommended security control in the low, moderate, or high baselines that provides equivalent or comparable protection for an information system. (SOURCE: CNSSI-4009)

- Compliance: A discipline, set of practices, and/or organizational group that deals with adhering to laws, regulations, standards, and contractual arrangements. Also, the adherence to requirements. Data Governance programs often support many types of compliance requirements: Regulatory compliance, contractual compliance, adherence to internal standards, policies, and architectures, and conformance to rules for data management, project management, and other disciplines. (SOURCE: Data Governance Institute)

- Comprehensive Testing: A test methodology that assumes explicit and substantial knowledge of the internal structure and implementation detail of the assessment object. Also known as white box testing. (SOURCE: NIST SP 800-53A)

- Compromise: Disclosure of information to unauthorized persons or a violation of the security policy of a system in which unauthorized intentional or unintentional disclosure, modification, destruction, or loss of an object may have occurred. (SOURCE: NIST SP 800-32; CNSSI-4009)

- Component: A discrete, identifiable information technology asset (e.g., hardware, software, firmware) that represents a building block of an information system. Information system components include commercial information technology products. Also referred to as a system component. (SOURCE: NIST SP 800-53r4)

- Computer-Based Training: Computer-based training (CBT) is any course of instruction whose primary means of delivery is a computer. A CBT course (sometimes called courseware) may be delivered via a software product

installed on a single computer, through a corporate or educational intranet, or over the Internet as Web-based training (SOURCE: TechTarget)

- Computer Cryptography: Use of a crypto-algorithm program by a computer to authenticate or encrypt/decrypt information. (SOURCE: CNSSI-4009)

- Computer Emergency Response Team (CERT): Acronym for Carnegie Mellon University's "Computer Emergency Response Team." The CERT Program develops and promotes the use of appropriate technology and systems management practices to resist attacks on networked systems, limit damage, and to ensure continuity of critical services. (SOURCE: PCI DSS Glossary)

- Computer Network Attack (CNA): Actions taken through the use of computer networks to disrupt, deny, degrade, or destroy information resident in computers and computer networks or the computers and networks themselves. (SOURCE: CNSSI-4009)

- Computer Network Defense (CND): Actions taken to defend against unauthorized activity within computer networks. CND includes monitoring, detection, analysis (such as trend and pattern analysis), and response and restoration activities. (SOURCE: CNSSI-4009)

- Computer Network Exploitation (CNE): Enabling operations and intelligence collection capabilities conducted through the use of computer networks to gather data from target or adversary information systems or networks. (SOURCE: CNSSI-4009)

- Confidentiality: Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information. (SOURCE: NIST SP 800-53; NIST SP 80053A; NIST SP 800-18; NIST SP 800-27; NIST SP 800-60; NIST SP 800-37; FIPS 200; FIPS 199; 44 U.S.C., Sec. 3542) The property that sensitive information is not disclosed to unauthorized individuals, affiliates, or processes. (SOURCE: FIPS 140-2) The property that information is not disclosed to system affiliates (users, processes, devices) unless they have been authorized to access the information. (SOURCE: CNSSI-4009)

- Configuration Control: Process of controlling modifications to hardware, firmware, software, and documentation to protect the information system against improper modification prior to, during, and after system implementation. (SOURCE: CNSSI-4009; NIST SP 800-37; NIST SP 800-53)

- Configuration Item: Any component or other service asset that needs to be managed in order to deliver an IT service. (SOURCE: ITIL V3)

- Configuration Management: A structured process of managing and controlling changes to hardware, software, firmware, communications, and documentation throughout the system development life cycle. (SOURCE: IRS PUB 1075)

- Container: The file used by a virtual disk encryption technology to encompass and protect other files. (SOURCE: NIST SP 800-111)

- Contamination: Type of incident involving the introduction of data of one security classification or security category into data of a lower security classification or different security category. (SOURCE: CNSSI-4009)

- Content Filtering: The process of monitoring communications such as email and Web pages, analyzing them for suspicious content, and preventing the delivery of suspicious content to users. (SOURCE: NIST SP 800-114)

- Contingency Plan: Management policy and procedures used to guide an enterprise response to a perceived loss of mission capability. The Contingency Plan is the first plan used by enterprise risk managers to determine what happened, why, and what to do. It may point to the Continuity of Operations Plan (COOP) or Disaster Recovery Plan for major disruptions. (SOURCE: CNSSI-4009)

- Continuity of Operations (COOP) Plan: A predetermined set of instructions or procedures that describe how an organization's mission essential functions will be sustained within 12 hours and for up to 30 days as a result of a disaster event before returning to normal operations. (SOURCE: NIST SP 800-34) Management policy and procedures are used to guide an enterprise's response to a major loss of enterprise capability or damage to its facilities. The COOP is the third plan needed by the enterprise risk managers and is used when the enterprise must recover (often at an alternate site) for a specified period of time. Defines the activities of individual departments and agencies and their sub-components to ensure that their essential functions are performed. This includes plans and procedures that delineate essential functions, specify succession to office and the emergency delegation of authority, provide for the safekeeping of vital records and databases, identify alternate operating facilities, provide for interoperable communications, and validate the capability through tests, training, and exercises. (SOURCE: CNSSI-4009)

- Continuous Monitoring: The process implemented to maintain a current security status for one or more information systems or for the entire suite of information systems on which the operational mission of the enterprise depends. The process includes: 1. The development of a strategy to regularly evaluate selected IA controls/metrics, 2. Recording and evaluating IA relevant events and the effectiveness of the enterprise in dealing with those events, 3. Recording changes to IA controls, or changes that affect IA risks, and 4. Publishing the current security status to enable information-sharing decisions involving the enterprise. (SOURCE: CNSSI-4009) Maintaining ongoing awareness to support organizational risk decisions. (SOURCE: NIST SP 800- 137)

- Control: A means of managing risk or ensuring that an objective is achieved. Controls can be preventative, detective, or corrective and can be fully automated, procedural, or technology-assisted human-initiated activities. They can include actions, devices, procedures, techniques, or other measures. (SOURCE: Data Governance Institute)

- Controlled Access Area: Physical area (e.g., building, room, etc.) to which only authorized personnel are granted unrestricted access. All other personnel are either escorted by authorized personnel or are under continuous surveillance. (SOURCE: CNSSI-4009)

- Controlled Area: Any area or space for which the organization has confidence that the physical and procedural protections provided are sufficient to meet the requirements established for protecting the information and/or information system. (SOURCE: NIST SP 800-53)

- Cookie: A piece of state information supplied by a Web server to a browser in a response for a requested resource for the browser to store temporarily and return to the server on any subsequent visits or requests. (SOURCE: NIST SP 800-28) Data is exchanged between an HTTP server and a browser (a client of the server) to store state information on the client side and retrieve it later for server use. (SOURCE: CNSSI-4009)

- Corrective Action Plan (CAP): A report required to be filed semi-annually, detailing the agency's planned and completed actions to resolve findings identified during an IRS safeguard review. (SOURCE: IRS PUB 1075)

- Countermeasures: Actions, devices, procedures, techniques, or other measures that reduce the vulnerability of an information system. Synonymous with security controls and safeguards. (SOURCE: NIST SP 800-53; NIST SP 800-37; FIPS 200)

- Covert Testing: Testing is performed using covert methods and without the knowledge of the organization's IT staff but with the full knowledge and permission of upper management. (SOURCE: NIST SP 800-115)

- Container: The file used by a virtual disk encryption technology to encompass and protect other files. (SOURCE: NIST SP 800-111)

- Critical Infrastructure: Systems and assets, whether physical or virtual, so vital to the U.S. that the incapacity or destruction of such systems and assets would have a debilitating impact on security, national economic security, national public health or safety, or any combination of those matters. [Critical Infrastructures Protection Act of 2001, 42 U.S.C. 5195c(e)] (SOURCE: CNSSI-4009)

- Criticality: A measure of the degree to which an organization depends on the information or information system for the success of a mission or a business function. (SOURCE: NIST SP 800-60)

- Criminal Justice Information (CJI): Criminal Justice Information is the term used to refer to all of the FBI Criminal Justice Information Services provided data necessary for law enforcement and civil agencies to perform their missions, including, but not limited to, biometric, identity history, biographic, property, and case/incident history data. The following categories of CJI describe the various data sets housed by the FBI CJIS architecture: - Biometric Data - data derived from one or more intrinsic physical or behavioral traits of humans, typically for the purpose of uniquely identifying individuals from within a population. It is used to identify individuals; it can include fingerprints, palm prints, iris scans, and facial recognition data. - Identity History Data - textual data that corresponds with an individual's biometric data, providing a history of criminal and/or civil events for the identified individual. - Biographic Data - information about individuals associated with a unique case and not necessarily connected to identity data. Biographic data does not provide a history of an individual, only information related to a unique case. - Property Data - information about vehicles and property associated with a crime when accompanied by any personally identifiable information (PII). - Case/Incident History - information about the history of criminal incidents. (SOURCE: FBI)

- Cryptographic Algorithm: A well-defined computational procedure that takes variable inputs, including a cryptographic key, and produces an output. (SOURCE: NIST SP 800-21; CNSSI-4009)

- Cyber Attack: A disabling attack via cyberspace, targeting an enterprise's use of cyberspace for the purpose of disrupting, destroying, or maliciously controlling a computing environment/infrastructure; or destroying the integrity of the data or stealing controlled information. (SOURCE: CNSSI-4009)

- Cyber Incident: Actions taken through the use of computer networks that result in an actual or potentially adverse effect on an information system and/or the information residing therein. See Incident. (SOURCE: CNSSI-4009)

- Cyber Infrastructure: Includes electronic information and communications systems and services and the information contained in these systems and services. Information and communications systems and services are composed of all hardware and software that process, store, and communicate information or any combination of all of these elements. Processing includes the creation, access, modification, and destruction of information. Storage includes paper, magnetic, electronic, and all other media types. Communications include the sharing and distribution of information. For example: computer systems; control systems (e.g., supervisory control and data acquisitionSCADA); networks, such as the Internet; and cyber services (e.g., managed security services) are part of cyber infrastructure. (SOURCE: NISTIR 7628)

- Cybersecurity: The ability to protect or defend the use of cyberspace from cyberattacks. (SOURCE: CNSSI-4009)

- Cybersecurity Event: A change that may have an impact on organizational operations (including mission, capabilities, or reputation). (SOURCE: NIST CYBERSECURITY FRAMEWORK)

- Cyberspace: A global domain within the information environment consisting of the interdependent network of information systems infrastructures, including the Internet, telecommunications networks, computer systems, and embedded processors and controllers. (SOURCE: CNSSI-4009)

DOCUMENT HISTORY

ORIGINAL SUBMISSION				
SUBMITTED ON	SUBMITTED BY	APPROVED BY	ISSUED DATE	EFFECTIVE DATE

REVISIONS		
LAST REVISION DATE	LAST REVISED BY	LAST APPROVED BY

REVIEWS		
LAST REVIEW DATE	LAST REVIEWED BY	NEXT REVIEW DATE